

(a) Marco integrativo GQM + PRAGMATIC para indicadores CTEM

1. Objetivo del marco

Este documento define un marco integrativo que combina la metodología **GQM** (Goal–Question–Metric) con los nueve criterios **PRAGMATIC** para el diseño y evaluación de indicadores CTEM (Gestión Continua de la Exposición a Amenazas) aplicados a objetivos nacionales y sectoriales.

El propósito es garantizar:

- Trazabilidad desde objetivos estratégicos nacionales hasta métricas técnicas.
- Coherencia entre preguntas de gestión y datos operativos.
- Calidad de las métricas evaluada de forma sistemática.

2. Recordatorio rápido: GQM y PRAGMATIC

2.1. GQM

- Goal (Objetivo): Qué se quiere lograr, en un contexto dado, desde la perspectiva de un stakeholder.
- Question (Pregunta): Qué hay que preguntar para saber si el objetivo se cumple.
- Metric (Métrica): Qué datos concretos hay que recoger para responder a la pregunta.

2.2. PRAGMATIC

Cada métrica se evalúa en nueve dimensiones, con una escala sugerida 0–2 (0 = débil, 1 = aceptable, 2 = fuerte):

1. Predictivo: ¿Ayuda a anticipar resultados futuros o sólo describe el pasado?
2. Relevante: ¿Está alineada con los objetivos y decisiones clave?
3. Accionable: ¿Sugiere acciones concretas cuando la métrica cambia?
4. Genuino: ¿Refleja la realidad sin distorsiones ni efectos colaterales perversos?
5. Significativo: ¿Es comprensible y tiene peso para quienes deciden?
6. Preciso: ¿Se puede medir con exactitud suficiente y coherente?
7. Oportuno: ¿Está disponible con la frecuencia y latencia adecuadas?
8. Independiente: ¿No se ve excesivamente manipulada por incentivos o sesgos?
9. Rentable: ¿Aporta más valor que coste de obtenerla y mantenerla?

3. Objetivos nacionales CTEM – esqueleto GQM

Se asumen cuatro objetivos estratégicos a nivel nacional/territorial para España:

10. ON1 – Reducir la exposición sistémica a amenazas en sectores esenciales y administraciones públicas.
11. ON2 – Mejorar la capacidad de remediación y respuesta, reduciendo el tiempo en cerrar exposiciones críticas.
12. ON3 – Aumentar la resiliencia y continuidad de servicios esenciales frente a incidentes cibernéticos.

13. ON4 – Alinear la gestión de exposición con marcos normativos europeos (NIS2, DORA, etc.) y demostrarlo con métricas.

Sobre estos objetivos se articulan preguntas de gestión y métricas CTEM derivadas.

4. GQM aplicado a indicadores CTEM clave

4.1. Indicador 1 – Superficie de ataque cubierta por CTEM

Goal (ON1): Reducir la exposición sistémica asegurando que los activos críticos nacionalmente relevantes están cubiertos por programas CTEM.

Questions:

- Q1.1: ¿Qué porcentaje de activos críticos de las organizaciones reguladas está inventariado y dentro del alcance de CTEM?
- Q1.2: ¿Qué porcentaje de esos activos dispone de descubrimiento continuo de exposición externa e interna?

Metrics:

- M1.1: Porcentaje de activos críticos inventariados frente a estimación total (por organización, luego agregado).
- M1.2: Porcentaje de activos críticos con herramientas de descubrimiento continuo activas.
- M1.3: Porcentaje de organizaciones con un programa CTEM que cubre explícitamente activos críticos.

4.2. Indicador 2 – Exposición priorizada y rutas de ataque explotables

Goal (ON1/ON2): Concentrar los esfuerzos en las exposiciones más peligrosas, reduciendo el número de rutas de ataque explotables hacia activos críticos.

Questions:

- Q2.1: ¿Cuántas rutas de ataque explotables hacia activos críticos se han identificado por organización?
- Q2.2: ¿Qué proporción de la exposición total corresponde a exposiciones con amenaza activa conocida?

Metrics:

- M2.1: Número de rutas de ataque explotables por activo crítico.
- M2.2: Porcentaje de exposiciones críticas asociadas a amenazas activas (según inteligencia de amenazas).
- M2.3: Densidad de exposiciones críticas por activo crítico (exposiciones/activo).

4.3. Indicador 3 – Eficacia de remediación (SLAs, MTTR, velocidad)

Goal (ON2): Mejorar la capacidad de remediación para que las exposiciones críticas se reduzcan de forma medible y sostenida.

Questions:

- Q3.1: ¿Qué porcentaje de exposiciones críticas se remedia dentro de los SLAs definidos?

- Q3.2: ¿Cuál es el tiempo medio de remediación (MTTR) de exposiciones priorizadas?
- Q3.3: ¿Cómo evoluciona la velocidad de remediación (reducción de exposición por unidad de tiempo)?

Metrics:

- M3.1: % de cumplimiento de SLAs de remediación para exposiciones críticas.
- M3.2: MTTR (en días) de exposiciones críticas desde detección hasta cierre.
- M3.3: Variación mensual del índice de exposición en activos críticos (score CTEM agregado).

4.4. Indicador 4 – Validación adversarial y eficacia de controles

Goal (ON2/ON3): Asegurar que las exposiciones identificadas se corresponden con riesgos explotables y que los controles responden adecuadamente.

Questions:

- Q4.1: ¿Qué porcentaje de exposiciones críticas se han validado como explotables mediante pruebas o simulaciones?
- Q4.2: ¿Qué tasa de éxito tienen los escenarios adversariales frente a los controles de seguridad actuales?

Metrics:

- M4.1: % de exposiciones críticas validadas como explotables.
- M4.2: % de escenarios BAS/red team donde los controles fallan (tasa de éxito del atacante simulado).
- M4.3: Tiempo medio en implementar mejoras de control tras una validación fallida.

4.5. Indicador 5 – Resiliencia y tiempo de recuperación de servicios esenciales

Goal (ON3): Reducir el impacto de incidentes en servicios esenciales, disminuyendo el tiempo de interrupción y mejorando la continuidad.

Questions:

- Q5.1: ¿Cuál es el tiempo medio de recuperación de servicios críticos (MTTR de servicio) tras incidentes?
- Q5.2: ¿Qué porcentaje de incidentes provoca interrupciones significativas para la ciudadanía o el negocio?

Metrics:

- M5.1: Tiempo medio de recuperación (horas/días) de servicios esenciales tras incidentes graves.
- M5.2: % de incidentes que generan interrupción de servicio superior a un umbral (por ejemplo, 1 hora).
- M5.3: Reducción interanual del número de incidentes con interrupción significativa.

4.6. Indicador 6 – Alineamiento con marcos normativos y transparencia

Goal (ON4): Garantizar que la gestión de exposición responde a NIS2, DORA y marcos asociados, y que se reporta adecuadamente.

Questions:

- Q6.1: ¿Qué porcentaje de entidades reguladas integran métricas CTEM en sus informes regulatorios?

- Q6.2: ¿Qué grado de uso se hace de marcos NIST/ISO/MITRE para estructurar métricas?
- Q6.3: ¿Con qué oportunidad y calidad se reportan incidentes significativos?

Metrics:

- M6.1: % de entidades NIS2/DORA que incluyen indicadores CTEM en sus informes.
- M6.2: % de entidades que declaran usar NIST CSF, ISO 27001 o MITRE ATT&CK para estructurar CTEM.
- M6.3: Tiempo medio de notificación de incidentes significativos y completitud de la información.

5. Evaluación PRAGMATIC de las métricas

Cada métrica Mi se evalúa en los nueve criterios PRAGMATIC con una puntuación sugerida de 0 a 2:

- 0 = Débil: la métrica apenas cumple el criterio.
- 1 = Aceptable: cumple el criterio de forma razonable.
- 2 = Fuerte: cumple el criterio de manera ejemplar.

La matriz detallada se recoge en el documento (b), pero el uso recomendado es:

14. Definir las métricas CTEM a nivel nacional/sectorial.
15. Evaluarlas con PRAGMATIC.
16. Ajustar o descartar aquellas que no lleguen a un umbral mínimo (por ejemplo, puntuación total < 10/18 o < 12/18).
17. Revisar periódicamente la evaluación a medida que mejoran datos, procesos y tecnología.

6. Flujo de trazabilidad GQM + PRAGMATIC

18. Definir objetivos nacionales (ON1–ON4).
19. Derivar preguntas de gestión (qué quiere saber el responsable nacional/regulador/sectorial).
20. Diseñar métricas CTEM que respondan esas preguntas (datos técnicos, de negocio y de resiliencia).
21. Evaluar las métricas con PRAGMATIC:
22. Descartar las que sean muy poco predictivas, poco accionables o demasiado costosas.
23. Mejorar la definición de las prometedoras.
24. Implementar la recogida de datos en encuestas, plataformas CTEM y repositorios nacionales.
25. Revisar objetivos, preguntas y métricas al menos cada 2 años o tras cambios regulatorios/tecnológicos relevantes.

7. Notas de implementación

- Es preferible tener pocas métricas muy PRAGMATIC que muchas métricas decorativas.
- La PRAGMATICidad de una métrica puede mejorar con el tiempo: por ejemplo, una métrica inicialmente costosa o imprecisa puede volverse rentable y precisa con mejor automatización.
- El marco GQM + PRAGMATIC puede utilizarse también a nivel organizacional, no sólo nacional; basta con ajustar los objetivos (Goal) al contexto interno.